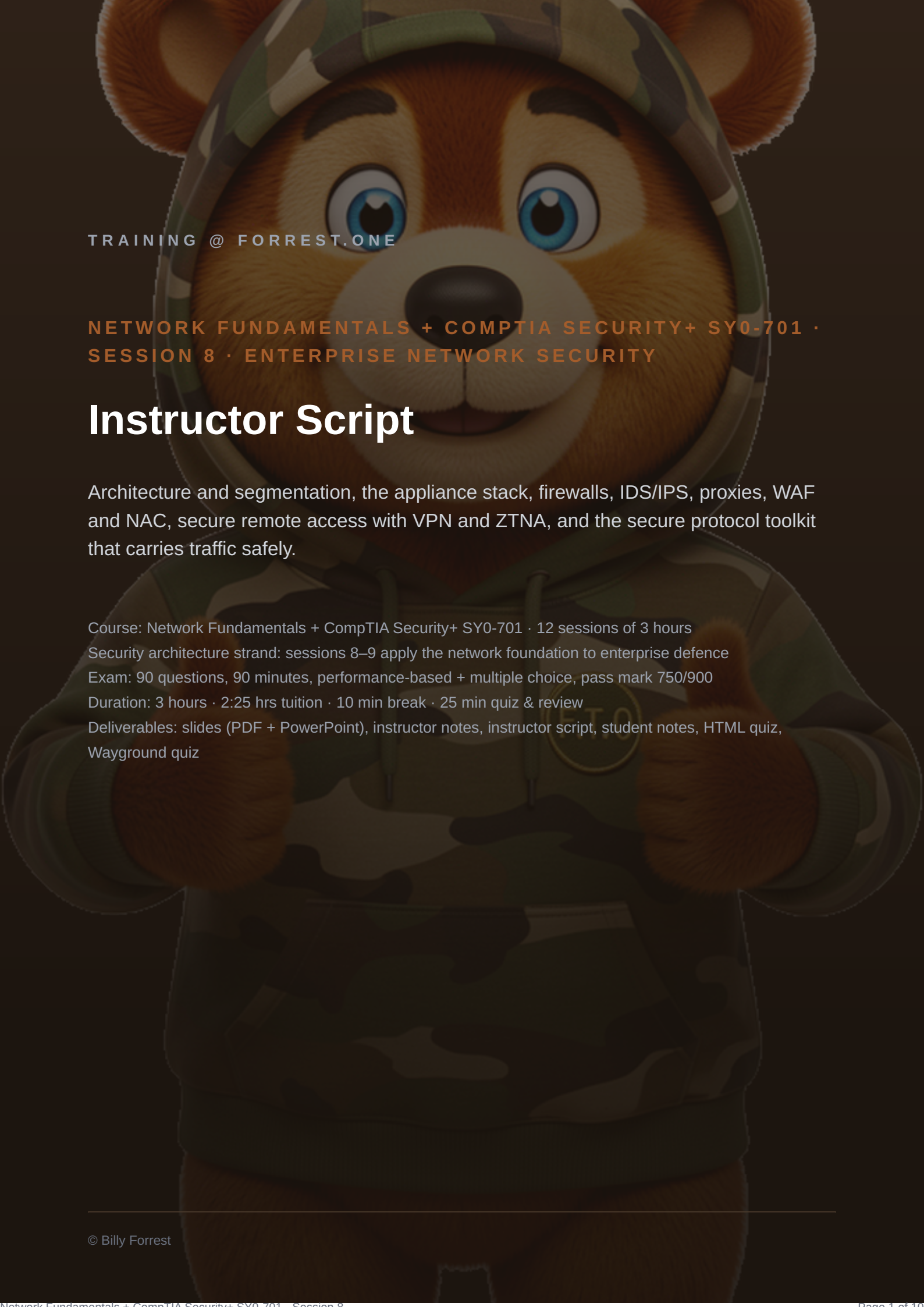




TRAINING @ FORREST.ONE

**NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 8 · ENTERPRISE NETWORK SECURITY**

Instructor Script

Architecture and segmentation, the appliance stack, firewalls, IDS/IPS, proxies, WAF and NAC, secure remote access with VPN and ZTNA, and the secure protocol toolkit that carries traffic safely.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

Security architecture strand: sessions 8–9 apply the network foundation to enterprise defence

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Script — Enterprise Network Security

A word-for-word delivery script for Session 8, following the expanded narration spine. Stage directions appear in square brackets. Each slide runs roughly 45 to 90 seconds of speech; activities and discussions expand the timings in the instructor notes.

Slide 1 · Title

Welcome to Session 8: Enterprise Network Security. Sessions one to three gave you the network foundation: addressing, switching, services. Sessions four to seven gave you the security core. Today we put them together, and we go further than the appliances. We start at the door with physical controls, then segment the network, decide who and what may join it, protect the keys and the content, and finish by describing the whole picture as trust zones. Keep the scenario mindset: the exam describes a situation and asks you to place the control.

Slide 2 · The network foundation pays off

A quick orientation. The VLANs from session two are now containment controls. The cryptography from session six returns as key management. The SSH from session three returns in the protocol toolkit. Today the spine is physical space, segmentation, admission, keys and zones, with the appliance and protocol strand consolidated at the end as exam reference.

Slide 3 · Session objectives

By the end of these three hours you will be able to secure the physical layer, plan deception lawfully, prove controls with audits, segment a network by data sensitivity, handle special environments, onboard guests and personal devices, harden devices and admit only healthy ones, and protect keys and content. The quiz tests the exam-objective areas; the discussion and activities check the rest.

Slide 4 · The physical layer starts at the door

Physical security protects the rooms that hold your network. Equipment rooms hold servers, wiring closets hold your switches, and data centres hold everything. The wiring closet is the one people forget, and anyone who reaches it can cut links or fit a rogue device. A key lock is cheap but easily picked and copied. A combination lock removes the key, but a shared code is a shared secret. Electronic access control uses cards and fobs, and a lost card can be revoked the same day. Biometrics are hardest to share and costliest to run. [Ask the class to name every route into their own building before you continue.]

Slide 5 · Controls around the room

Around those locks you layer surveillance and visitor control. Cameras should cover every entry point with blind spots minimised, and the footage must be kept long enough to reconstruct an incident. That retention period is set by policy, and often by regulation. Visitors sign in and are escorted at all times. Access logs record who entered each secure space and when, and those logs are what you reach for during an investigation. A security guard adds a visible deterrent, and a person who can respond. Footage you have already deleted proves nothing.

Slide 6 · Honeypots and honeynets

A honeypot is a decoy system built to attract an attacker away from your real targets. A low interaction honeypot simulates only a few services, so it is simple and cheap to run. A high interaction honeypot runs a full operating system, so you watch the attacker use real tools and techniques. A honeynet is a whole network of decoys, and it makes lateral movement visible. Isolation is not optional. Without strict segmentation you have built the attacker a stepping stone rather than a trap. Internal decoys also catch insiders.

Slide 7 · Deceiving lawfully

Before you deploy a single decoy, understand the legal ground you stand on. You need consent to monitor, and staff may need to be informed. Privacy law still applies, because a decoy can capture personal data by accident, so configure it narrowly. And entrapment is a genuine risk. A honeypot must wait, observe and record. It must never solicit or encourage an attack. Get the paperwork right before you get clever, because a decoy that breaks the law is worse than none.

Slide 8 · Internal and external audits

An audit asks a harder question than a policy review. It asks whether your controls are in place, and whether they actually work. An internal audit is run by your own team, who know the systems deeply. An external third party assessment brings independence, and regulators often demand one. Preparation decides the outcome: gather your documents, collect evidence such as logs and configurations, brief your staff, and run a mock audit first. Afterwards you remediate every finding, then follow up and verify the fix.

Slide 9 · The regimes you will meet

Three regimes come up again and again. The Payment Card Industry Data Security Standard covers anyone handling card data, and it demands tight access control. The General Data Protection Regulation governs personal data belonging to people in the European Union: clear consent, and the right to see, correct and delete. Data locality adds another constraint, because some countries insist their citizens' records stay inside their borders, which decides which cloud regions you may use. And logs are your evidence. Compliance you cannot evidence is compliance you cannot claim.

Slide 10 · Campus network architecture

Architecture first. The tiered model: core for fast transport, distribution for policy, access for endpoints. Spine-leaf: the data-centre fabric where every leaf connects to every spine for low latency. SMB: flat and single-layer for small sites. Redundancy matters too: duplicate paths and devices, so a single failure does not bring the network down. The choice is driven by scale, budget, reliability and control needs.

Slide 11 · Why we divide the network

Segmentation divides one network into many, and the virtual local area network is the primary tool. A VLAN lets you take one physical switch and carve it into separate logical networks, so payroll, finance and engineering can share hardware while never sharing broadcast traffic. Between those segments, the firewall zone decides what may cross. Micro-segmentation goes further and applies policy to an individual workload, so a compromised web server cannot reach the database even when both sit on the same segment. The payoff is containment. Everything else is detection.

Slide 12 · Let data sensitivity set the trust level

Here is how to make the planning concrete. Classify your data first, and let that classification drive the design. A segment holding cardholder records or health data gets the highest controls, and only specific trusted devices and users may reach it. A public facing web server sits in a looser zone, because it must be reachable by strangers. It still gets monitoring and control, just not the same trust. That is segmentation by data sensitivity and trust level, and it is exactly what the card and health rules expect.

Slide 13 · Segmentation in practice

The mechanisms in practice. VLANs separate logically within a switch: different zones, different rules. The DMZ is a buffer zone hosting public services, ringed by two firewalls, an external one guarding the DMZ and an internal one shielding the LAN. Micro-segmentation isolates even within a workload. Least connectivity means you allow only the connections you actually need. The benefit is the same throughout: a compromise in one segment does not spread everywhere.

Slide 14 · Internet of things and industrial systems

Some environments need special treatment. Internet of things devices, from door sensors to cameras, are cheap, rarely patched, and often shipped with default credentials. Industrial internet of things devices run production, and operational technology drives physical processes. Those networks are legacy by design and speak protocols nobody fully understands any more. Above all, availability outranks confidentiality, because stopping a production line is worse than almost any data loss. So give each family its own segment, and remember: a compromised sensor must never reach the corporate network.

Slide 15 · The Purdue model

Industrial networks often follow a model called Purdue, and the shape is worth knowing. Levels zero and one are the field devices, the sensors and actuators touching the physical world. Level two is process control, where the programmable logic controllers live. Level three is site operations, running manufacturing execution systems. Level four is enterprise information technology, your business systems. Traffic between every layer is controlled and monitored. Where even that is not enough, you air gap the network, which means physical isolation from everything else.

Slide 16 · Availability first in operational technology

Understand why operational technology is treated differently. You cannot simply patch an industrial controller in the middle of a production run, and rebooting it may be physically dangerous. So the controls shift from hardening the device to containing the segment. Isolate it behind firewalls, restrict what may cross, and watch the traffic closely for anomalies. Where the risk is severe enough, you accept inconvenience and air gap it. If you cannot fix the device, control its neighbourhood.

Slide 17 · Discussion

[Run the discussion per the instructor notes.] Why do internet of things sensors belong on their own segment? Weak patching, default credentials, no authentication, and an availability requirement that outranks confidentiality. Compromised, they become pivot points into the whole network. Segment by trust, not by convenience.

Slide 18 · Designing a guest network

Guest networks are a design problem with a clear answer. Start with a separate segment, its own VLAN, so a guest device sits nowhere near your internal resources. Then deny internal access outright, using firewall rules and access control lists that block the path between the guest segment and everything else. Cap the bandwidth as well, so a guest streaming video cannot steal capacity from your staff. Finally, put a captive portal in front of it: the guest signs in and accepts your terms of use.

Slide 19 · The captive portal earns its place

The captive portal is more useful than it first appears. When a guest joins, they are redirected to a web page before any internet access is granted. That page carries your acceptable use policy, and agreement is recorded. It also gives you a name or an address for the access log, which is useful when something goes wrong. And it gives you a place to publish changed terms later. The portal is a control point, not just a splash screen.

Slide 20 · Bring your own device

Bring your own device is the same problem with a personal twist. Convenience is real, and so is the risk, because you do not own the hardware. So again you segment, placing personal devices on their own network with limited reach into your resources. Then you enrol them in mobile device management, which lets you enforce policy such as encryption and screen lock. Certificate based authentication proves each device is one you know, and lets you revoke it when it is lost. The trade is convenience against attack surface.

Slide 21 · Making personal devices safe enough

A bring your own device programme needs rules people can follow. Write down what a compliant personal device looks like, and make enrolment a condition of connecting. When the device enrolls, you issue it a certificate, so the network recognises it and you can revoke it later. Where the platform allows, keep work data separate from personal data. And be ready to remove corporate data from a lost device without touching the owner's photographs. Publish the policy and get agreement before enrolment. People accept rules they can read.

Slide 22 · Break

Ten minutes. When we return: hardening the devices you own, and the gate they must pass through before they join.

Slide 23 · Reducing the attack surface

Device hardening is simple in principle and neglected in practice. Every service, port and protocol a device runs is somewhere an attacker can knock. So you remove what you do not need, which shrinks the attack surface and simplifies management at the same time. Start with credentials, because default usernames and passwords are published and every attacker already has them. Then disable unused services, close unused ports, and disable unused protocols. Apply firmware and security patches promptly, and automate it so it actually happens.

Slide 24 · Baselines, compliance and minimal functionality

Hardening is not a one-off task, it is a regime. Define a secure configuration baseline, one documented standard for each type of device. Then verify compliance, auditing every device against that baseline and using automated tools to catch drift. Devices do drift, because someone changes a setting and nobody records it. The principle behind the baseline is minimal functionality: a device should do only the job you bought it for, so a router routes and does not host a website. Fewer features means less to defend.

Slide 25 · Use a published guide, not your memory

Do not invent your baseline from memory. Use the published hardening guides, because they have already done the work. The Centre for Internet Security publishes benchmarks for common devices and operating systems. The National Institute of Standards and Technology publishes frameworks that government and industry both follow. And most vendors publish a hardening guide for their own products. Build your baseline from those, then verify compliance with automated checks and regular audits. A baseline nobody checks is only a document.

Slide 26 · Network access control: posture assessment

Network access control is the gatekeeper at the front door. Before a device joins, it proves its security posture. The check covers antivirus presence and currency, operating system patches, configuration settings, and the user credentials. A device that fails is either denied outright or quarantined into a restricted segment. A remediation network then lets it reach patch servers and antivirus updates, so it can fix itself and try again. Agent based checking installs software and gives rich detail; agentless checking installs nothing, which is easier and shallower.

Slide 27 · Port based authentication: 802.1X

The technology underneath network access control is port based authentication, usually called eight oh two point one X. It authenticates a device at the switch port, before any real traffic can flow. Three roles are involved: the device is the supplicant, the switch is the authenticator, and a central server makes the decision. That server is usually RADIUS, which stands for remote authentication dial in user service, and it centralises authentication, authorisation and accounting. The switch relays the exchange, and a port left unauthenticated can be dropped into a guest segment. No authentication, no traffic.

Slide 28 · Roll network access control out in phases

One practical warning about deploying network access control. It is easy to lock out your own staff by accident. A compliance check that misfires will quarantine a perfectly healthy laptop, and that user will call you. So deploy in phases. Pilot in a small, controlled environment, run in monitor mode first to see what it would have blocked, then refine your policies. Expand segment by segment, watching for false positives as you go. Test before you enforce, and you keep both security and goodwill.

Slide 29 · The life of a key

Key management is the discipline that keeps cryptography honest. A key has a life, and every stage of it can fail. Generation must use a secure random number generator, seeded from real entropy such as hardware noise, because predictable keys are no keys at all. Distribution is the hard part, especially for symmetric keys, where sender and receiver must hold the same value; you protect it in transit with an encrypted channel, wrapping it in asymmetric encryption. Then storage, rotation, revocation and destruction. Poor key management defeats perfect cryptography.

Slide 30 · Where keys live

Let me separate the storage options, because they are examined. A hardware security module is a physical device. It holds keys and performs the cryptographic operations itself, so the key never appears on the host system. A key vault is software, storing keys with access controls, auditing and logging around them. A secure enclave is an isolated area inside the processor, protected even from the operating system. And a key management system ties it together with central control. Store keys where they cannot be casually read.

Slide 31 · Rotation limits the blast radius

Why does rotation matter so much? If a key is disclosed and it never changes, the attacker decrypts everything, past and future. So you rotate on a schedule, which limits how much any single compromise can expose. Keep the retired key only as long as you need it to read data that was already encrypted. Then revoke it, so it can never authorise anything again. Then destroy it everywhere it was stored, including backups. Rotation limits the blast radius.

Slide 32 · Access control lists and URL filtering

Filtering is how written policy becomes enforcement. An access control list is a list of rules on a router or switch, permitting or denying traffic by source address, destination address, port or protocol. Order matters enormously, because the device evaluates the rules in sequence and stops at the first match. Put a permit everything rule at the top, and the rest of the list becomes decoration. URL filtering works at a higher level, blocking whole categories of site through a web proxy, and DNS based filtering blocks the name lookup before any connection even exists.

Slide 33 · Inspecting what flows

Beyond the address rules, you inspect what the traffic actually contains. Content filtering scans for known malware signatures, and blocks the file before it lands on a machine. Deep packet inspection is the mechanism, examining packet contents in real time. Data loss prevention looks the other way, outbound, hunting for sensitive patterns leaving the building and stopping the transfer. A web proxy sits in the middle, enforcing those policies, caching popular content, and hiding your internal addresses. Filtering decides what is allowed, and inspection decides what is safe.

Slide 34 · Trust zones and the screened subnet

Network zones are how you describe trust in architecture. The untrusted zone is the internet, which anyone can reach and nobody controls. The trusted zone holds your internal resources, your data centres and your private cloud, and only authorised users and devices reach it. Between them sit the semi-trusted zones, where partner networks, branch offices and guest networks belong. A screened subnet, often called a demilitarised zone or DMZ, is a buffer holding public facing services. It is reachable from the internet, and deliberately separated from your internal network. Trust is a design decision, not a location.

Slide 35 · Zone policy, defence in depth and zero trust

Two ideas finish the architecture. The first is zone based policy with deliberate asymmetry: your internal users may reach the demilitarised zone, but the zone may not reach back in, so a compromised public server cannot become a doorway. Layer that with defence in depth, meaning firewalls, detection, encryption and monitoring all stacked, because no single control is foolproof. The second idea is zero trust. It discards the assumption that anything inside the trusted zone is safe, and verifies identity and context on every request.

Slide 36 · Exam reference: the appliance stack

This slide consolidates the appliance strand, and the exam distinctions are all here. A stateless firewall filters each packet alone by address, port and protocol, with no context. A stateful firewall keeps a state table and tracks each connection, so established flows are allowed through sensibly. A next-generation firewall adds application awareness, deep packet inspection and threat intelligence, and UTM bundles the lot into one box for small and medium businesses. Intrusion detection watches, alerts and logs; intrusion prevention sits inline and blocks. Signatures catch known attacks, and anomaly detection finds deviations. And proxies, web application firewalls and load balancers each have a job. [Do not read every cell: walk the columns.]

Slide 37 · Activity: place the appliance

[Run the activity per the instructor notes. 8 minutes in pairs, 4 minutes debrief.] Which appliance inspects application-layer web attacks? The web application firewall. Which blocks malicious traffic inline? The IPS. Which should not be a single point of failure? The load balancer. Which hides the internal topology? The proxy. And the debrief: what happens when each fails? That is how exam scenarios are written.

Slide 38 · Exam reference: remote access

Remote access, consolidated. A site-to-site VPN connects whole networks, branch to headquarters, and often runs IPsec in tunnel mode. A remote access VPN connects one device: client-based software, or an SSL VPN that works in the browser over TLS with no client install, which suits contractors. Split tunnel sends only some traffic through the tunnel and the rest direct, which is convenient but does not protect everything. ZTNA verifies identity and posture per request, with no implicit network trust, and SASE delivers ZTNA plus SD-WAN as a service. Every remote path needs authentication, encryption and monitoring, and for RDP that means multi-factor authentication, firewall allowlists, patching, monitoring, and jump servers or bastion hosts for administrators.

Slide 39 · Activity: lock down remote access

[Run the activity per the instructor notes.] RDP must stay enabled for one admin: add multi-factor authentication, firewall allowlists, patching and monitoring, and MFA again. Branch users need HQ systems: site-to-site VPN. A contractor needs browser-only access: SSL VPN. And the non-negotiable control across all of them is multi-factor authentication.

Slide 40 · Exam reference: the secure protocol toolkit

Match the protocol to the job. TLS and HTTPS: transport encryption for web and APIs, with TLS one point two and one point three current while SSL and TLS one point zero and one point one are dead. SSH and SFTP: secure remote administration and file transfer. IPsec: network-layer encryption for VPNs, in tunnel mode for whole networks. S/MIME: email signing and encryption. DNSSEC: DNS response integrity. HSTS: browsers refuse plaintext connections for the domain. Perfect forward secrecy uses ephemeral keys, so past traffic stays secret even if a key leaks, and certificate validation checks the chain, the hostname, the expiry and the revocation status, which is what defeats a man in the middle.

Slide 41 · Key takeaways

The takeaways to carry forward. Physical access defeats every logical control, so secure the rooms first. Deception gives you intelligence, provided the decoy is isolated and the monitoring is lawful. Audits prove controls work, and your evidence is logs, configurations and access records. Segmentation contains a breach, and you plan it from data sensitivity, treating industrial systems separately. Guests and personal devices never inherit internal trust. Harden by removing what is not needed, then admit only devices that pass a posture check. And keys and content move through zones: rotate keys, filter what may cross, and verify identity on every request.

Slide 42 · Revision checklist

Before next session: retake the quiz until you score seventy percent without guessing. Draw a zone diagram, untrusted, screened subnet, internal and management, for a network you know. Match the controls to the risks: physical, segmentation, admission, keys, filtering and zones. And read ahead to Session 9: endpoint, application, cloud and virtualisation security.

Slide 43 · Quiz

[Direct candidates to Quiz_Session_08.html. 15 minutes.] Open the session quiz. Twenty questions, immediate feedback, and every question is tagged with its topic area, so you will see the tag, like 8C Secure Remote Access, above each question. Read every explanation, because the distractors teach as much as the answers. Aim for seventy percent or better. The Wayground version is available for in-class assessment.

Slide 44 · Next session preview

Next time, Endpoint, Application, Cloud and Virtualisation Security. We harden the hosts, with operating system baselines, endpoint detection and response, and mobile device management. We secure the code, through the secure development lifecycle and the application attacks that abuse it. And we move to the cloud: service models, the shared responsibility model and the hypervisor. If you take one habit from today, make it this: segment by trust, and prove everything else. See you there.